Security Audit Benchmark — Executive Scorecard

OWASP Juice Shop · source-code audit · 11 Nov 2026

What was tested

We pointed five tools at the same deliberately-vulnerable web application (OWASP Juice Shop) and asked each to review the source code and find real security bugs. Nobody ran the app or attacked a live site — this was a read-only reading of the code. We froze a list of 30 headline bugs BEFORE scoring (the "Core 30"), picked mechanically from the app's own vulnerability categories so no one could tune the result. "Found" means the tool pointed at the right file with the right kind of bug.

How many of the 30 headline bugs each tool found

Tool	Headline bugs found (of 30)	False alarms
AISA CLI v1.5.1 (this engine)	**25**	0
ChatGPT (web)	7	0
Codex (web, defensive prompt)	11	0
Claude.ai (web, partial run)	10	0
All three web AIs combined	14	—
Gemini 2.5 Pro (web)	refused the task	—

Wider view (secondary numbers): across the full 60-bug set, the CLI matched 46 by exact bug, more than the three web AIs combined (29). Counting more loosely — any bug found anywhere in the right file — the field is closer: CLI 53 of 60, web AIs 45–48 each. False alarms were 0 for every tool, because this app is vulnerable on purpose, so there was little to get wrong.

What this means

1. On the headline bugs, the CLI engine found more than twice what any single web AI found (25 of 30 vs 7–11), and more than all three web AIs combined (14).

2. The CLI's edge is biggest on exact, provable bugs; on loose "right-file" credit the tools are close, so the engine's real advantage is precision and completeness, not finding something the web AIs cannot.

3. The CLI still missed 5 of the 30 (the chatbot/LLM bugs, the admin-section guard, one reflected-XSS spot and the deleted-user login) — honest gaps in this run, not hidden.

Core 30 was frozen before scoring; selection rule and full per-bug results: tests/benchmark/core30.md and tests/benchmark/juice-shop.labels.json in github.com/risewithvj/AI-Security-Audit-Skills. Engine: AISA v1.5.1, auto profile, ~9 min read-only run.